PayFlow

Product Requirements Document — Merchant Payment Processing Platform (v3.0)

Status: Approved for Development | Owner: Payments Platform Team | Version 3.0 | Classification: Internal

1. Executive Summary

PayFlow is a merchant-facing payment processing platform that enables online and in-app businesses to accept card payments, manage settlements, and reconcile transactions through a single unified API and dashboard. PayFlow sits between merchants and the card networks / banking rails, tokenizing sensitive cardholder data, screening transactions for fraud in real time, and settling funds to merchant bank accounts on a T+2 cycle. This document defines the requirements for the v3.0 release, which introduces a redesigned tokenization vault, an in-house fraud engine, and expanded ACH payout support.

2. Problem Statement & Objectives

Small and mid-sized merchants currently integrate with multiple disconnected providers (gateway, fraud tooling, payouts), increasing PCI DSS scope and integration cost. PayFlow consolidates these into one PCI DSS Level 1 certified platform.

- Reduce merchant PCI compliance burden via hosted tokenization (SAQ A eligibility).
- Process card-present and card-not-present transactions with sub-300ms authorization latency.
- Provide real-time fraud scoring with a false-positive rate below 0.4%.
- Support same-day ACH payouts for verified merchants by Q3.

3. Target Users & Personas

Persona	Description	Primary Needs
Merchant Admin	Owner/finance lead at a merchant account	Onboarding, payout visibility, dispute management
Merchant Developer	Integrates PayFlow SDK/API into checkout	Clear API docs, sandbox, webhooks, idempotency
Support / Ops Agent	Internal PayFlow staff	Case tools, transaction lookup, manual review queue
Compliance Officer	Internal risk & compliance	AML/KYC review, audit trail export, SAR tooling

4. Scope

4.1 In Scope

- Hosted card tokenization (web + mobile SDK) and server-to-server API.

- Real-time authorization, capture, refund, and void flows.
- In-house rules + ML-based fraud scoring engine.
- Ledger, settlement batching, and merchant payout via ACH and same-day rails.
- Merchant dashboard for transaction search, disputes, and reporting.
- Webhook event delivery (payment.succeeded, payment.failed, payout.completed, dispute.opened).

4.2 Out of Scope (this release)

- In-person / POS terminal hardware integration.
- Cryptocurrency settlement.
- Buy-now-pay-later financing products.

5. Functional Requirements

5.1 Merchant Onboarding & KYC

- FR-1: System shall collect business legal entity information and beneficial ownership data.
- FR-2: System shall invoke a third-party KYC/AML provider to verify identity and screen against OFAC/sanctions lists before activation.
- FR-3: System shall support tiered onboarding (Standard vs. Enhanced Due Diligence) based on risk score.

5.2 Payment Processing

- FR-4: System shall tokenize raw PAN data at the edge (client-side SDK or hosted fields) so raw card numbers never touch merchant servers.
- FR-5: System shall route authorization requests to the appropriate card network (Visa, Mastercard, Amex) via ISO 8583 messaging to the acquiring bank.
- FR-6: System shall support partial and full refunds within 180 days of original transaction.
- FR-7: System shall enforce idempotency keys on all mutating API requests.

5.3 Fraud & Risk

- FR-8: System shall score every transaction in real time using device fingerprint, velocity, and behavioral signals prior to authorization.
- FR-9: System shall allow merchants to configure custom rule thresholds (block/review/allow) per risk tier.
- FR-10: System shall route review-flagged transactions to an internal analyst queue with a 2-minute SLA.

5.4 Settlement & Payouts

- FR-11: System shall batch and net transactions nightly and initiate ACH payouts to merchant bank accounts.
- FR-12: System shall maintain a double-entry ledger of all fund movements, immutable and independently auditable.
- FR-13: System shall support merchant-initiated payout holds pending dispute investigation.

5.5 Reporting & Notifications

- FR-14: System shall deliver signed webhook events for all state changes with automatic retry and replay.
- FR-15: System shall provide downloadable settlement and reconciliation reports (CSV/PDF).

6. System Architecture Overview

PayFlow follows a layered microservices architecture (see attached Architecture Diagram). Client traffic (merchant dashboard, mobile SDK, server-to-server API) terminates at a CDN/WAF layer and an API gateway, which enforces authentication, rate limiting, and request validation before routing to backend services. The Card Tokenization Service and Token Vault operate inside a restricted PCI DSS scope segment isolated by network policy from the rest of the application estate. The Payment Orchestration Service coordinates calls to card networks and the banking partner, while the Fraud Detection Engine consumes a real-time event stream to score transactions before authorization completes. All services publish domain events to a Kafka-based event bus consumed by the Ledger, Notification, and Audit Log services.

- Client Layer: Merchant Web Dashboard (React SPA), Mobile Capture SDK (iOS/Android), Partner Server-to-Server API clients.
- Edge/Perimeter: CloudFront CDN, AWS WAF, Kong API Gateway (authn, rate limiting), Application Load Balancer.
- Application Services: Auth Service (OAuth2/OIDC), Payment Orchestration Service, Card Tokenization Service, Fraud Detection Engine, Ledger & Settlement Service, Notification Service.
- Data Stores: Transactions DB (PostgreSQL, AES-256 at rest), Token Vault (HSM-backed, PCI scope), Redis (session/rate-limit cache), Immutable Audit Log Store (S3 + Object Lock), Kafka event bus.
- External Dependencies: Card Networks (Visa/Mastercard/Amex), Banking Partner ACH rails, KYC/AML Provider, Fraud Intelligence Feed, SMS/Email Provider.

7. Data Classification & Sensitive Data Inventory

Data Type	Classification	Where Stored	Regulatory Driver
Primary Account Number (PAN)	Restricted / PCI	Token Vault only (tokenized), never in app DB	PCI DSS
CVV	Restricted / PCI	Never persisted, memory-only during auth	PCI DSS
Bank account / routing numbers	Restricted / Financial	Ledger DB, encrypted column-level	GLBA, PCI DSS
KYC identity documents	Confidential / PII	Encrypted object storage, KYC vendor	AML/KYC, GDPR/CCPA
Transaction metadata	Internal	Transactions DB	SOX (financial reporting)
Merchant credentials / API keys	Restricted	Secrets manager (KMS-wrapped)	Internal security policy

8. Authentication, Authorization & Session Management

- Merchant dashboard users authenticate via OAuth2/OIDC with mandatory MFA (TOTP or WebAuthn) for admin roles.
- Server-to-server API access uses scoped API keys plus HMAC request signing; keys are rotatable and displayed once.
- Internal service-to-service calls use mutual TLS with short-lived SPIFFE-issued certificates.
- Role-based access control differentiates Merchant Admin, Developer (read-only prod keys), Support Agent (masked PAN view), and Compliance (full audit access).
- All access to the Token Vault requires a separate break-glass approval workflow logged to the immutable audit store.

9. Non-Functional Requirements

Category	Requirement
Availability	99.95% uptime for authorization path; multi-AZ active-active deployment
Latency	P95 authorization response under 300ms
Scalability	Support 2,000 transactions/second peak (holiday sale events)
Durability	Ledger and audit data replicated across 3 regions, 11 9's durability
Auditability	All PAN access, config changes, and payouts logged immutably for 7 years

10. Compliance & Regulatory Requirements

- PCI DSS Level 1 Service Provider certification required prior to GA.
- SOC 2 Type II report required for enterprise merchant sales.
- AML/BSA program including OFAC sanctions screening and suspicious activity reporting (SAR).
- GDPR/CCPA data subject rights for EU/CA merchant contacts and cardholders.

11. Assumptions, Constraints & Dependencies

- Acquiring bank relationship and card network certification are managed by a third-party payment facilitator partner.
- Token Vault HSM infrastructure is provisioned and managed by the Security Engineering team, not this product team.
- Fraud model training data depends on 6 months of historical transaction volume before ML scoring can outperform static rules.

12. Open Questions & Risks

- Should same-day ACH payouts require step-up authentication for high-value merchants?

- Risk: Fraud engine cold-start period may increase manual review queue load at launch.
- Risk: Card network certification timeline (~10 weeks) is on the critical path for GA.